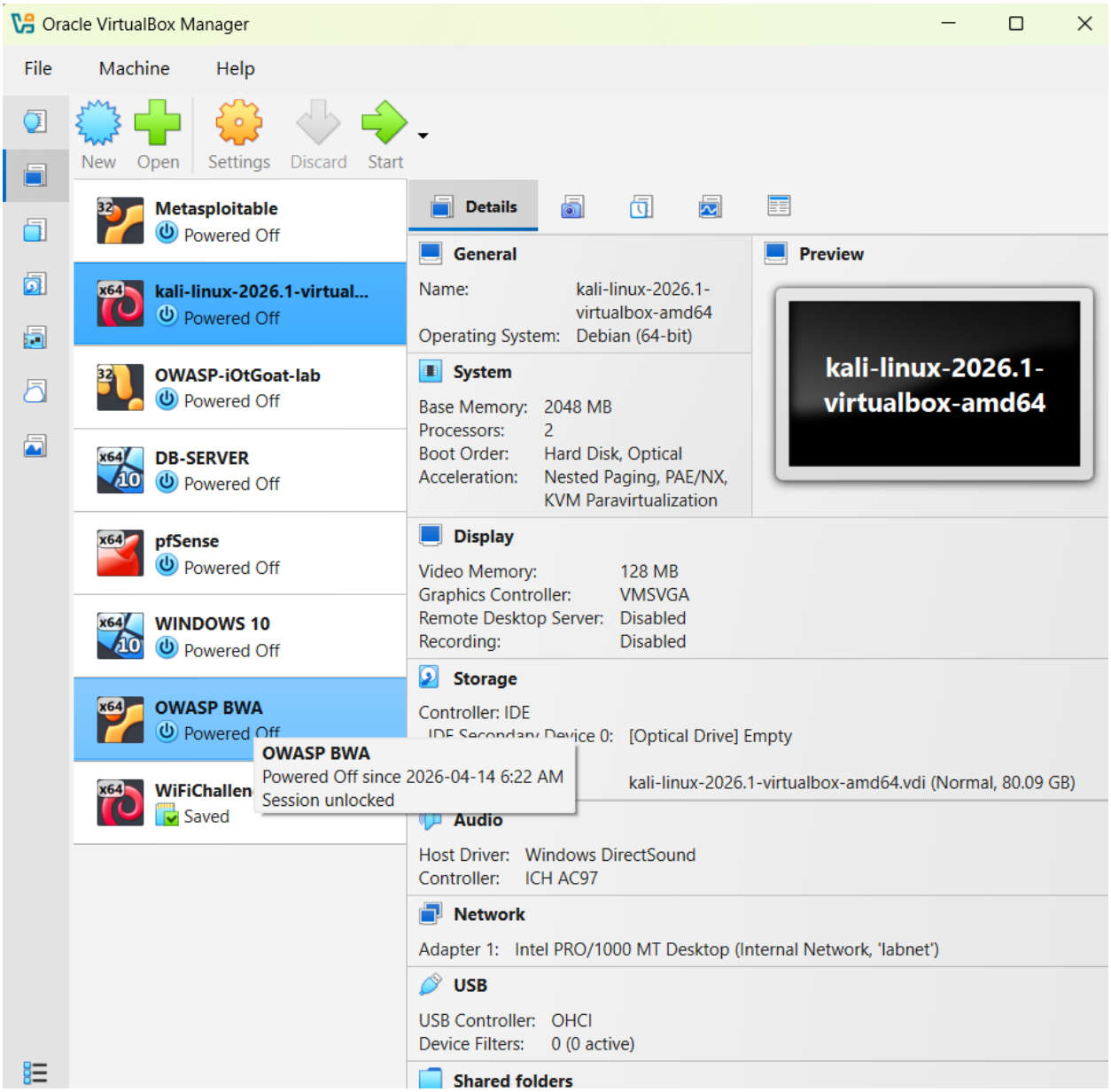
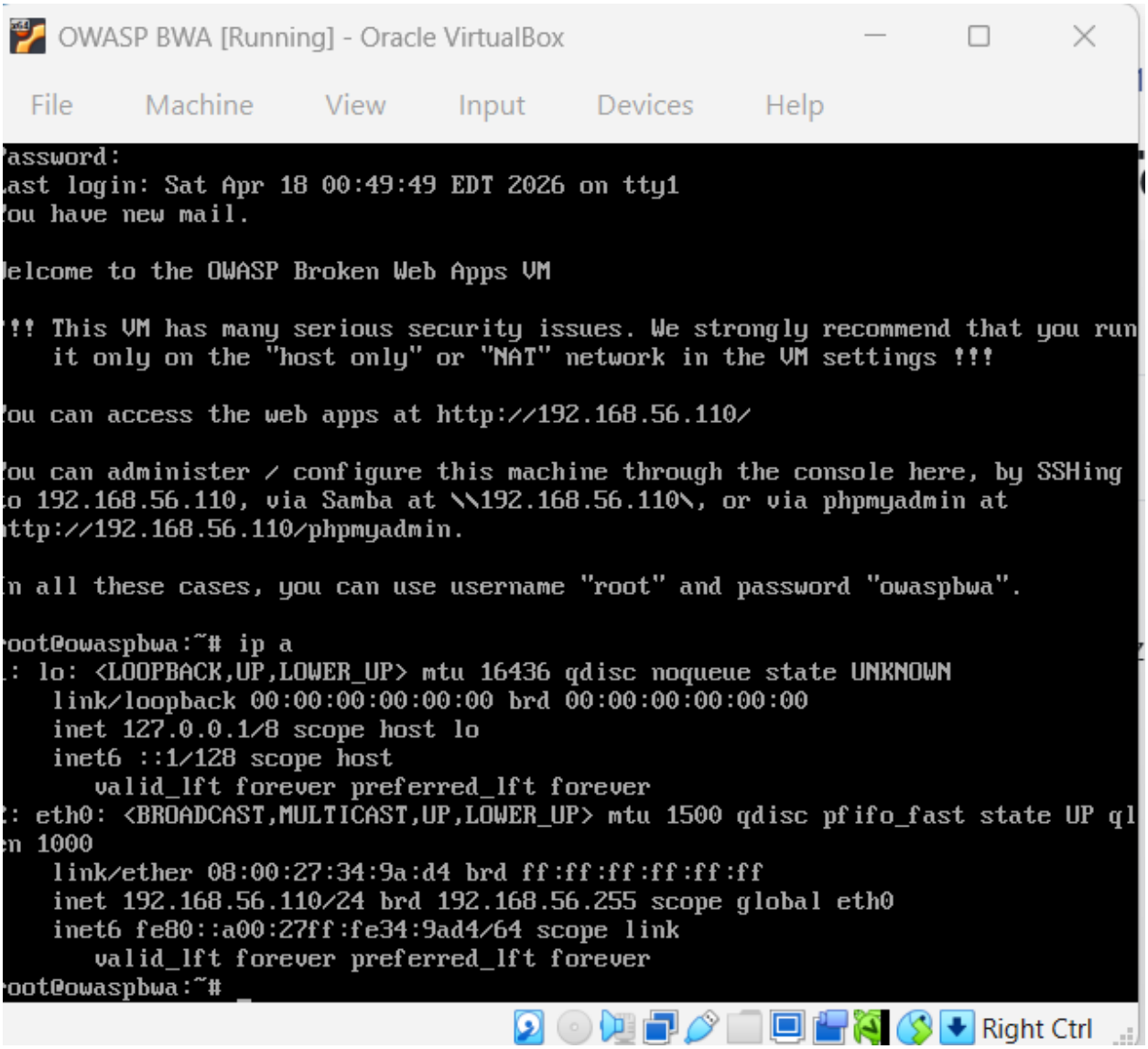
Black Box Penetration Test on Altoro Mutual

Using Kali and OWASP BWA**:**



Target Identification and Initial Reconniassance:



Network Discovery from Kali:

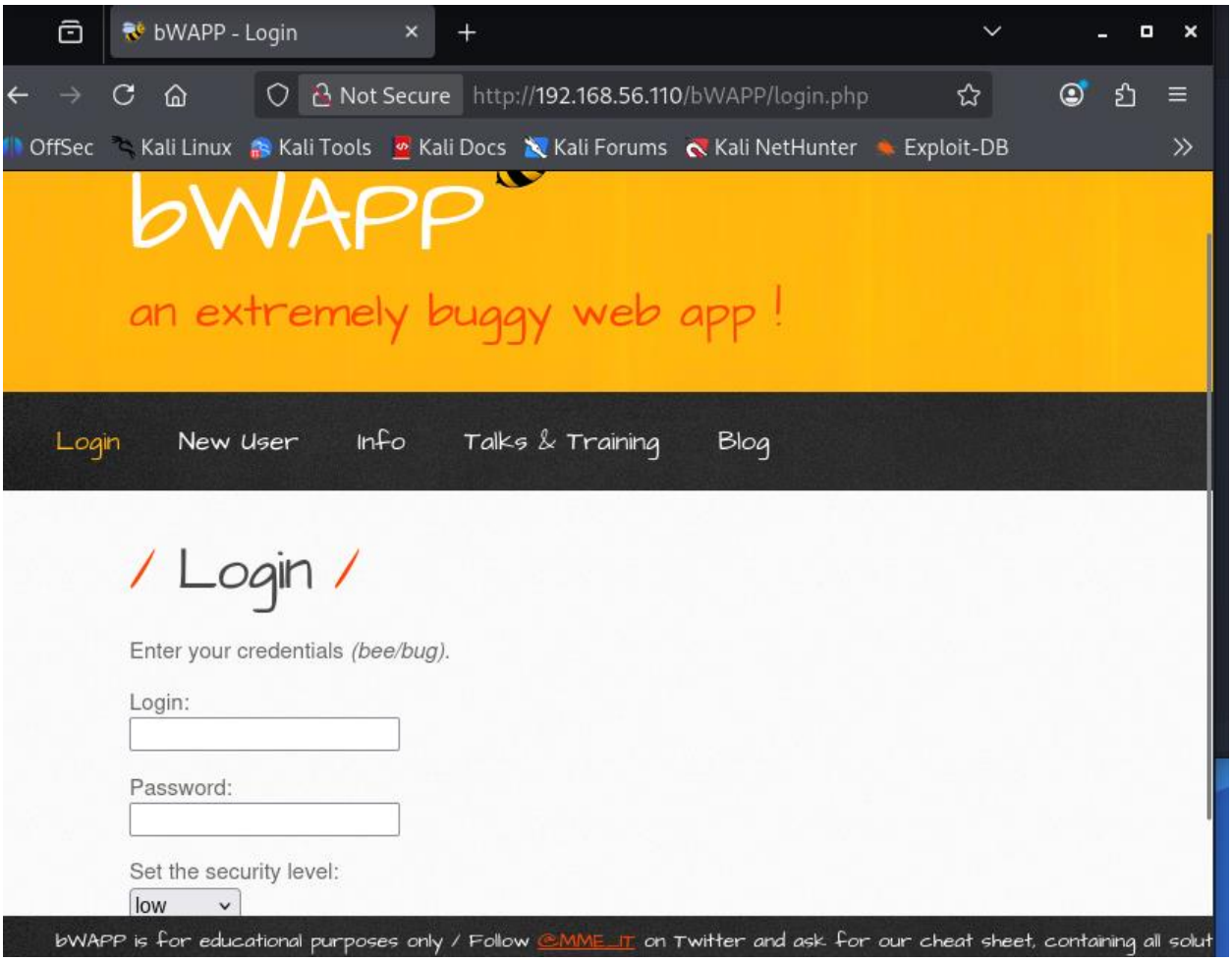
```
root@kali: ~
Session  Actions  Edit  View  Help
zsh: corrupt history file /root/.zsh_history
┌──(root㉿kali)-[~]
└─# nmap -sn 192.168.56.0/24
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-18 00:58 -0400
Nmap scan report for 192.168.56.1
Host is up (0.00073s latency).
MAC Address: 0A:00:27:00:00:0E (Unknown)
Nmap scan report for 192.168.56.100
Host is up (0.00039s latency).
MAC Address: 08:00:27:09:A0:D2 (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.56.110
Host is up (0.0011s latency).
MAC Address: 08:00:27:34:9A:D4 (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.56.104
Host is up.
Nmap done: 256 IP addresses (4 hosts up) scanned in 2.95 seconds

┌──(root㉿kali)-[~]
└─#
```

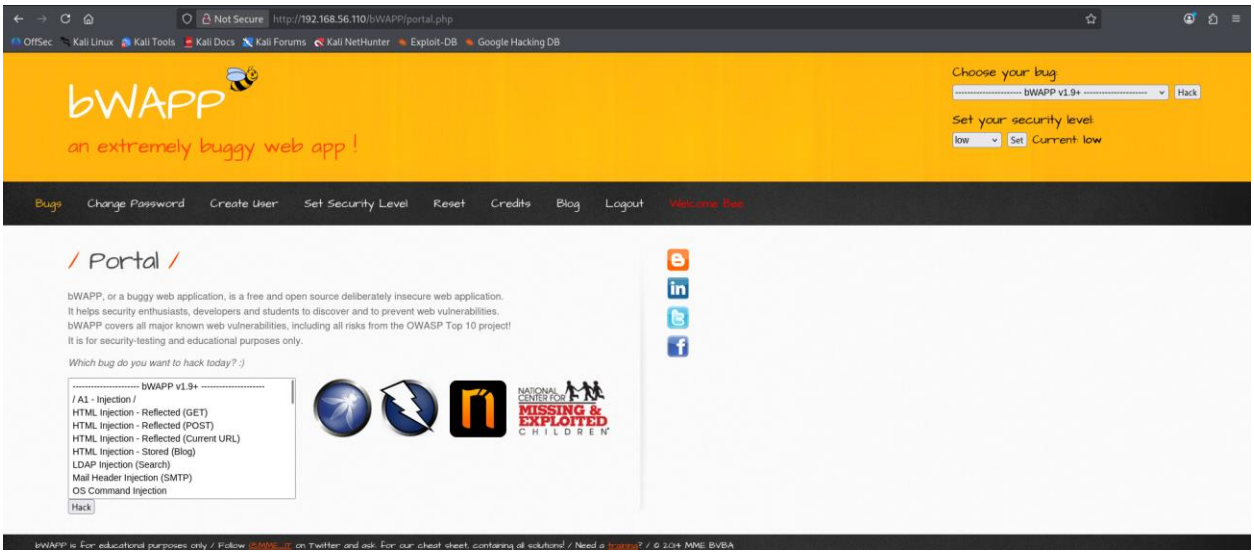
Target Application Identification: The target web application was accessed via the identified IP address within the controlled lab environment. The application selected for testing was Buggy Web App (Bwapp), an intentionally insecure web application designed to simulate real-world vulnerabilities.

bWAPP was used as a substitute for the originally specified target due to its availability within the testing environment and its comprehensive coverage of common web application vulnerabilities aligned with OWASP Top 10 categories.

Successful authentication was achieved using default credentials, indicating the presence of weak authentication controls.

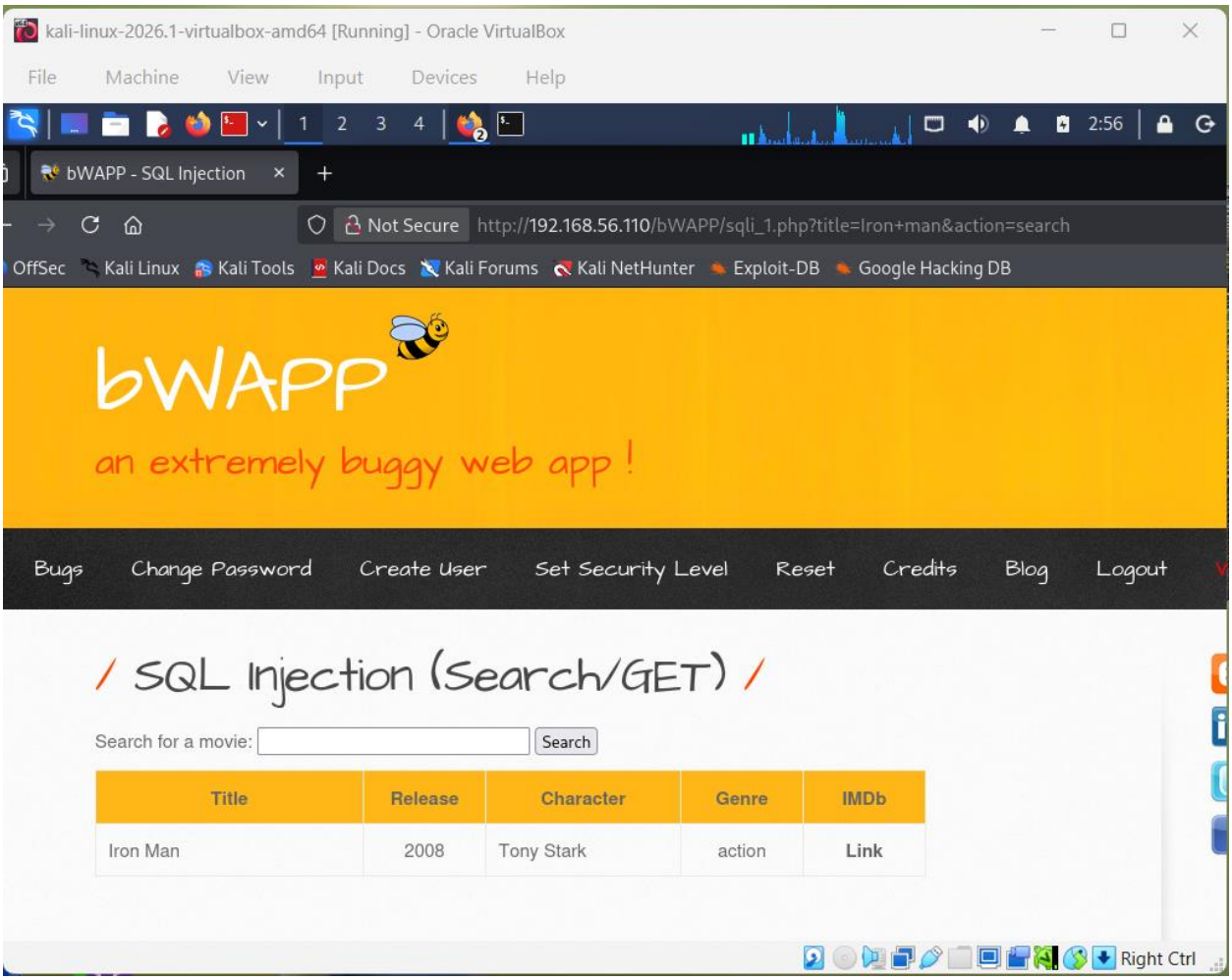

bWAPP - Login
Not Secure
http://192.168.56.110/bWAPP/login.php
OffSec
Kali Linux
Kali Tools
Kali Docs
Kali Forums
Kali NetHunter
Exploit-DB
bWAPP
an extremely buggy web app !
Login
New User
Info
Talks & Training
Blog
/ Login /
Enter your credentials (bee/bug).
Login:
Password:
Set the security level:
low
bWAPP is for educational purposes only / Follow @MME_IT on Twitter and ask for our cheat sheet, containing all solut

Dashboard:

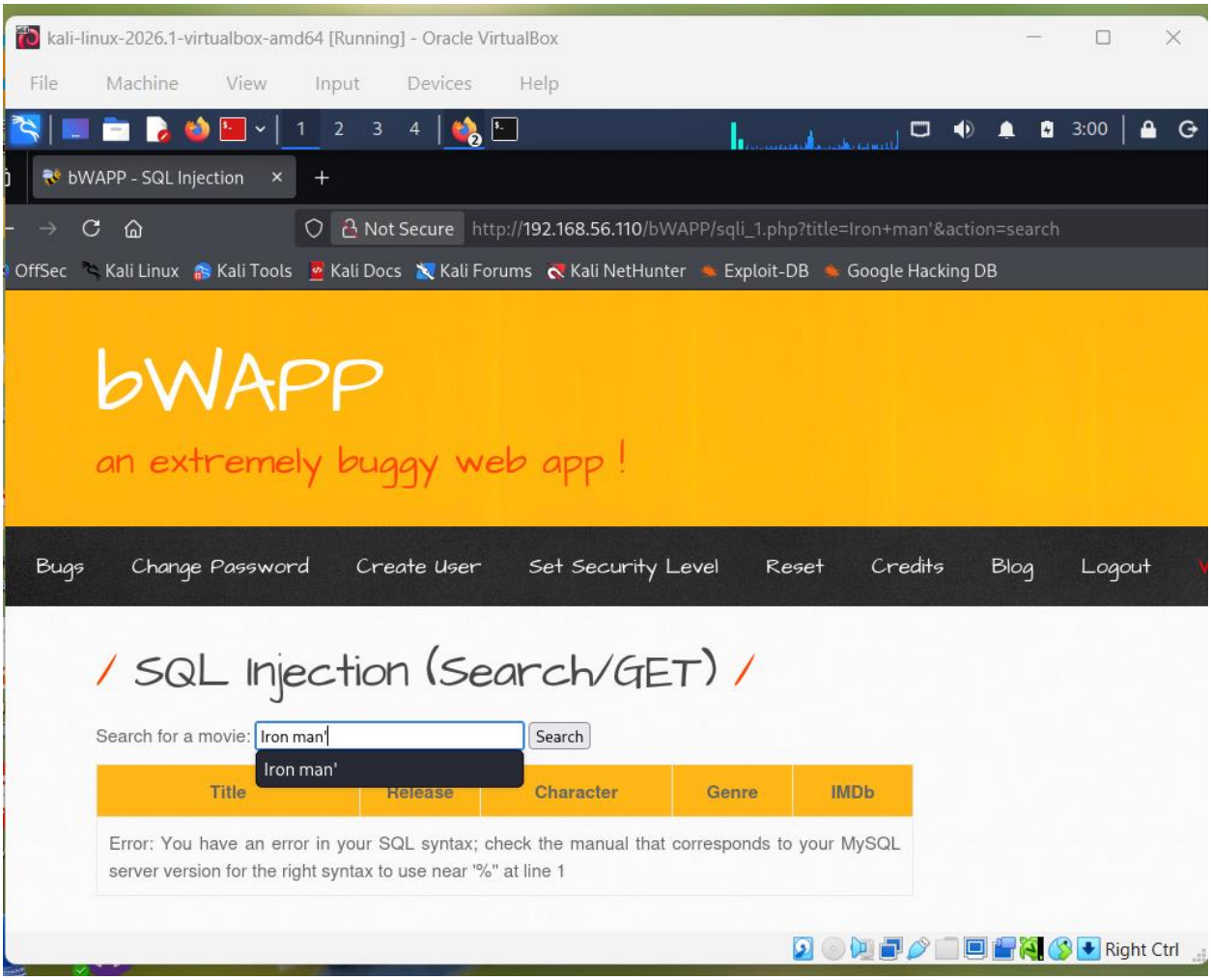

Not Secure
http://192.168.56.110/bWAPP/portal.php
OffSec
Kali Linux
Kali Tools
Kali Docs
Kali Forums
Kali NetHunter
Exploit-DB
Google Hacking DB
bWAPP
an extremely buggy web app !
Choose your bug
bWAPP v1.9+
Hack
Set your security level:
low
Set
Current: low
Bugs
Change Password
Create User
Set Security Level
Reset
Credits
Blog
Logout
Welcome Bee
/ Portal /
bWAPP, or a buggy web application, is a free and open source deliberately insecure web application.
It helps security enthusiasts, developers and students to discover and to prevent web vulnerabilities.
bWAPP covers all major known web vulnerabilities, including all risks from the OWASP Top 10 project!
It is for security-testing and educational purposes only.
Which bug do you want to hack today? :)
bWAPP v1.9+
/ A1 - Injection /
HTML Injection - Reflected (GET)
HTML Injection - Reflected (POST)
HTML Injection - Reflected (Current URL)
HTML Injection - Stored (Blog)
LDAP Injection (Search)
Mail Header Injection (SMTP)
OS Command Injection
Hack
NATIONAL CENTER FOR MISSING & EXPLOITED CHILDREN

SQL Injection:

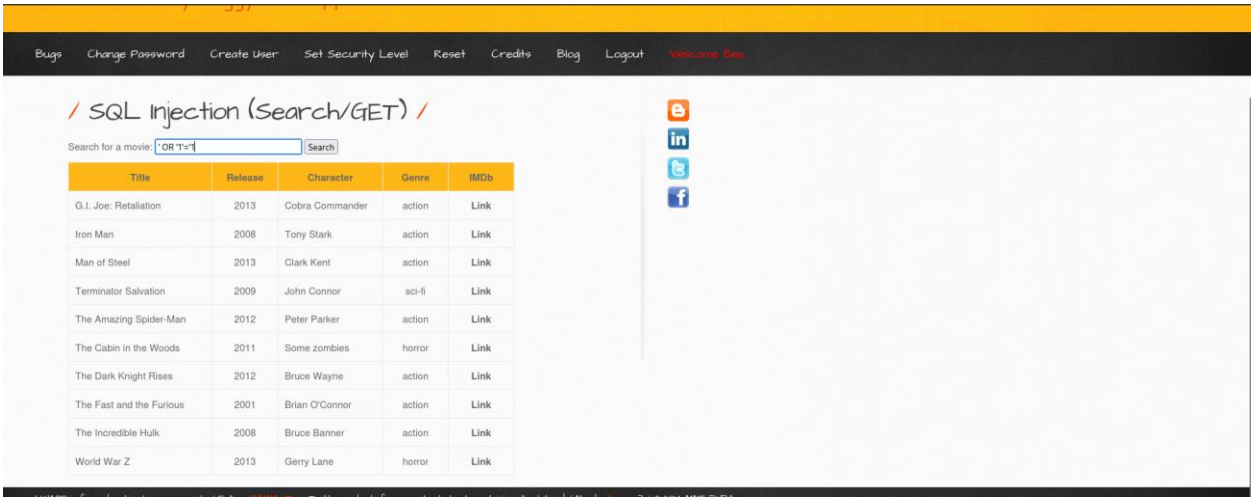
First lets see what is normal:



Testing for SQL injection vulnerability:



The injection payload successfully altered the SQL query logic, resulting in the retrieval of all records from the database, confirming exploitation of the vulnerability.



Vulnerability Access Gained

SQL Injection	Authenticated User
IDOR	Other User Data
Weak Auth	Multiple Accounts

Severity: Critical
CWE: CWE-89

REMEDIATION REPORT

SQL Injection

- Use prepared statements
- Implement parameterized queries

Host (IP)	Open Ports	Services	Obtained Access	Vulnerabilities Exploited
192.168.56.110	80	HTTP	User/System Access	SQLi, XSS, Command Injection